AFRICA'SPY

INTELLIGENCE ACADEMY

AFS-D201 | SUPPORT DE COURS ET FICHE DE SYNTHÈSE

Cyber Threat Intelligence et défense des communications

CTI, infrastructures, communications sécurisées et détection.

DOMAINE	Cyberespionnage et renseignement numérique
NIVEAU	Avancé
DURÉE INDICATIVE	20 heures
ÉDITION	13 novembre 2026

Document pédagogique réservé aux apprenants inscrits. Les scénarios, organisations et données cités dans les exercices et études de cas sont fictifs. AFRICA'SPY est un organisme de formation privé ; ce support ne vaut pas diplôme.

Présentation

La Cyber Threat Intelligence transforme des données techniques en **décisions de défense**. Cette formation fait le lien entre analystes de renseignement et équipes techniques (SOC, CSIRT), en couvrant les niveaux stratégique, opérationnel et tactique de la CTI.

Les travaux pratiques reposent sur des journaux et indicateurs synthétiques fournis par l'Académie.

Objectifs pédagogiques	Compétences visées
• Définir la CTI et ses trois niveaux • Utiliser le modèle en diamant et MITRE ATT&CK • Analyser une infrastructure numérique à partir de données publiques • Mettre en place des communications sécurisées • Détecter des activités suspectes dans des journaux	• Structurer un rapport CTI • Qualifier des indicateurs de compromission • Choisir des outils de communication chiffrée • Lire des journaux d'authentification

PRÉREQUIS

- Renseignement numérique et OSINT avancé
- Notions de réseaux informatiques (adresse IP, DNS)

SOMMAIRE

01 Intelligence sur les menaces : CTI

02 Analyse des infrastructures numériques

03 Sécurité des communications

04 Détection des activités numériques suspectes

05 Mise en situation : cellule CTI sectorielle

06 Atelier pratique

CHAPITRE 01

Intelligence sur les menaces : CTI

Niveaux, cycle et modèles d'analyse.

LEÇON Les fondamentaux de la CTI

La CTI applique le cycle du renseignement au domaine cyber. Elle répond à des questions comme : **qui pourrait nous viser, comment, et que devons-nous surveiller ?**

Trois niveaux

Niveau	Destinataire	Contenu
Stratégique	Direction	Tendances, acteurs, impacts métier
Opérationnel	Responsables sécurité	Campagnes, modes opératoires (TTP)
Tactique	SOC / équipes techniques	Indicateurs de compromission (IoC)

Le modèle en diamant

Chaque événement d'intrusion est décrit par quatre sommets reliés : **adversaire**, **capacité**, **infrastructure**, **victime**. Connaître un sommet permet de rechercher les autres.

La pyramide de la douleur

Bloquer une adresse IP gêne peu un attaquant (il en change facilement) ; détecter ses **TTP** (comportements) l'oblige à modifier ses méthodes, ce qui est beaucoup plus coûteux pour lui. La CTI vise donc le haut de la pyramide.

LEÇON Approfondissement : formats et partage de la CTI

Pour être exploitable par des machines, la CTI s'échange dans des formats normalisés :

- **STIX 2.1** (Structured Threat Information eXpression), standard OASIS décrivant objets et relations : acteurs, campagnes, indicateurs, techniques ;
- **TAXII**, protocole de transport des données STIX ;
- Des plateformes libres comme **MISP** permettent de partager des indicateurs au sein de communautés de confiance.

Qualité d'un indicateur

Un bon IoC est **contextualisé** (campagne, date d'observation, confiance), **daté** (les infrastructures changent vite) et accompagné d'un marquage TLP.

> **Points clés**
>
> - STIX décrit, TAXII transporte.
> - Un indicateur sans contexte génère des faux positifs.
> - Le partage se fait dans des communautés de confiance.

CHAPITRE 02

Analyse des infrastructures numériques

DNS, IP, certificats : lire Internet.

LEÇON Comprendre une infrastructure

Toute activité en ligne repose sur une infrastructure : noms de domaine, serveurs, adresses IP, certificats, hébergeurs. Ces éléments laissent des traces publiques exploitables légalement.

Sources ouvertes d'infrastructure

- **WHOIS / RDAP** : informations d'enregistrement (souvent masquées) ;
- **DNS historique** : évolution des résolutions d'un domaine ;
- **Journaux de transparence des certificats** : certificats émis pour un domaine ;
- **Moteurs d'exposition** recensant les services visibles sur Internet ;
- **Registres régionaux** (AFRINIC pour l'Afrique) : attribution des blocs d'adresses.

Exemple de raisonnement (données fictives)

Un domaine d'hameçonnage imitant une banque est hébergé sur une IP qui sert aussi trois autres domaines récemment enregistrés, imitant d'autres institutions financières. Hypothèse : une même campagne. Action : signalement aux CSIRT et aux registrars, alerte aux clients.

> L'analyse d'infrastructure reste passive : on consulte des registres publics, on n'interagit pas avec les systèmes d'un tiers au-delà d'un usage normal.

LEÇON Approfondissement : typosquattage et domaines trompeurs

Le **typosquattage** consiste à enregistrer des noms de domaine proches d'une marque (lettre inversée, tiret ajouté, extension différente, caractères visuellement similaires) pour tromper les utilisateurs.

Exemples de variantes (fictives)

```
banque-exemple.com   ->  banque-exernple.com  (rn au lieu de m)
                     ->  banqueexemple-ci.com
                     ->  banque-exemple.co
```

Défense

- Surveiller les nouveaux enregistrements de domaines proches de sa marque (services de veille, journaux de transparence des certificats) ;
- Enregistrer préventivement les variantes les plus évidentes ;
- Signaler les domaines frauduleux au registrar et au CERT national ;
- Mettre en place SPF, DKIM et DMARC pour limiter l'usurpation de ses adresses e-mail.

Points clés

- Les domaines proches sont un vecteur majeur d'hameçonnage.
- La surveillance est passive et légale.
- DMARC protège la réputation de sa messagerie.

CHAPITRE 03

Sécurité des communications

Chiffrement, authentification et bonnes pratiques.

LEÇON Communiquer en sécurité

Protéger ses communications est un droit et une nécessité professionnelle : journalistes, avocats, ONG, entreprises et administrations y sont confrontés.

Notions clés

- **Chiffrement en transit** (TLS) : protège le trajet entre vous et le serveur ;
- **Chiffrement de bout en bout** : seuls l'émetteur et le destinataire peuvent lire ;
- **Vérification des clés** : comparer les codes de sécurité pour éviter l'interposition ;
- **Métadonnées** : même chiffrées, les communications révèlent qui parle à qui et quand.

Bonnes pratiques

1. Authentification multifacteur sur toutes les messageries professionnelles ;
2. Applications à jour, verrouillage des appareils ;
3. Messages éphémères pour les échanges sensibles ;
4. Séparation des usages personnels et professionnels ;
5. Prudence avec les réseaux Wi-Fi publics.

> La sécurité d'une communication dépend du maillon le plus faible : un téléphone non verrouillé annule le meilleur chiffrement.

LEÇON Approfondissement : l'authentification multifacteur

L'**authentification multifacteur (MFA)** combine au moins deux éléments : ce que l'on sait (mot de passe), ce que l'on possède (téléphone, clé), ce que l'on est (biométrie).

Méthode	Robustesse	Commentaire
Code par SMS	Moyenne	Exposée aux détournements de carte SIM
Application d'authentification (codes temporaires)	Bonne	Fonctionne hors connexion
Notification « approuver »	Bonne si correspondance de nombre	Attention à la fatigue des notifications
Clé de sécurité FIDO2 / passkeys	Très élevée	Résistante à l'hameçonnage

Points clés

- Même un SMS vaut mieux que rien.
- Privilégier FIDO2 pour les comptes à privilèges.
- Ne jamais approuver une notification non sollicitée.

CHAPITRE 04

Détection des activités numériques suspectes

Lire des journaux et repérer l'anormal.

LEÇON Détecter l'anomalie

La détection consiste à repérer, dans le flux d'événements d'un système **que l'on est autorisé à surveiller**, ce qui s'écarte du comportement normal.

Signaux typiques dans les journaux d'authentification

- Nombreux échecs de connexion suivis d'un succès ;
- Connexion depuis un pays inhabituel ou à une heure atypique ;
- « Voyage impossible » : deux connexions éloignées géographiquement en peu de temps ;
- Création de règles de transfert automatique dans une messagerie ;
- Volume inhabituel de téléchargements.

Extrait de journal synthétique

```
2026-03-04 02:11:07 user=a.diallo  src=196.0.2.14  result=FAIL
2026-03-04 02:11:09 user=a.diallo  src=196.0.2.14  result=FAIL
2026-03-04 02:11:12 user=a.diallo  src=196.0.2.14  result=SUCCESS
2026-03-04 02:14:40 user=a.diallo  action=create_forward_rule dest=external
```

Lecture : connexion nocturne après échecs, puis création d'une règle de transfert vers l'extérieur : scénario classique de compromission de messagerie. Réponse : suspendre la session, réinitialiser le mot de passe, supprimer la règle, enquêter sur l'étendue.

> Une alerte n'est pas une preuve : il faut qualifier (vrai ou faux positif) avant d'agir, et documenter.

LEÇON Approfondissement : écrire une règle de détection

Les équipes de détection formalisent leurs hypothèses en **règles**. Le format ouvert **Sigma** permet de décrire une détection indépendamment de l'outil (SIEM) utilisé.

Exemple pédagogique simplifié

```
title: Création de règle de transfert de messagerie vers l'extérieur
logsource: { product: messagerie, service: audit }
detection:
  selection:
    action: create_forward_rule
    destination|endswith: externe
  condition: selection
level: high
```

Cycle de vie d'une règle

1. Hypothèse (tirée de la CTI) ;
2. Écriture et test sur données historiques ;
3. Mesure des faux positifs ;
4. Déploiement, puis revue périodique.

> **Points clés**
>
> - Une règle part d'une hypothèse documentée.
> - Tester avant de déployer.
> - Sigma facilite le partage entre organisations.

CHAPITRE 05

Mise en situation : cellule CTI sectorielle

Produire et partager une analyse de menace pour un secteur entier.

EXERCICE PRATIQUE Simulation guidée : bulletin CTI hebdomadaire du secteur bancaire

> **Scénario entièrement fictif.** Pays, organisations, personnes et données sont imaginaires et ne décrivent aucune situation réelle.

Vous animez la cellule CTI (fictive) d'une association de banques de la zone « UMOK ». Cette semaine, vous recevez :

- de la banque A : 3 domaines d'hameçonnage imitant son application mobile ;
- de la banque B : une hausse de tentatives de connexion depuis des adresses déjà signalées ;
- du CERT national : un avis sur une campagne de faux SMS de livraison ;
- d'un éditeur de sécurité : un rapport public sur un groupe ciblant les banques africaines.

Consignes

1. Rédigez un bulletin en trois niveaux : stratégique (5 lignes pour les directions générales), opérationnel (campagnes et TTP), tactique (indicateurs).
2. Attribuez un marquage TLP à chaque partie et justifiez.
3. Formulez trois recommandations mesurables.
4. Proposez un indicateur de performance du dispositif de partage.

Barème indicatif (auto-évaluation sur 20)

Critère	Points
Trois niveaux bien distingués	6
Marquages TLP justifiés	4

Critère	Points
Recommandations mesurables	5
Indicateur de performance pertinent	5

ÉTUDE DE CAS Étude de cas : le faux positif qui coûtait cher

> **Scénario entièrement fictif.** Pays, organisations, personnes et données sont imaginaires et ne décrivent aucune situation réelle.

Une banque bloque automatiquement une liste d'adresses IP reçue d'un partenaire. Parmi elles figure l'adresse d'un fournisseur de services de paiement partagée par de nombreux clients : les paiements en ligne sont interrompus pendant six heures.

1. Quelles informations manquaient à l'indicateur (contexte, date, confiance) ?
2. Quelle procédure de qualification aurait évité l'incident ?
3. Comment la pyramide de la douleur éclaire-t-elle le choix de détecter des comportements plutôt que des adresses ?

LEÇON Fiche méthode : modèle de bulletin CTI

```
BULLETIN CTI N° [..]   PÉRIODE : [..]   MARQUAGE GLOBAL : TLP:[..]
1. SYNTHÈSE STRATÉGIQUE (direction)         : 5 lignes, impact métier
2. CAMPAGNES OBSERVÉES (sécurité)           : description, TTP (ATT&CK), cibles
3. INDICATEURS (SOC)                        : type | valeur | 1re/dernière observation |
confiance
4. RECOMMANDATIONS                          : action | responsable | échéance
5. SOURCES                                  : émetteur | date | fiabilité
```

Points clés

- Chaque indicateur porte une date et un niveau de confiance.
- La synthèse stratégique ne contient pas de jargon.

CHAPITRE 06

Atelier pratique

Rapport CTI et analyse de journaux synthétiques.

EXERCICE PRATIQUE Exercice : analyser un journal synthétique

Le jeu de données fourni (fictif) contient 200 lignes d'authentification d'une organisation imaginaire sur une semaine.

1. Établissez le profil normal (horaires, origines, volumes).
2. Identifiez au moins trois anomalies et qualifiez-les.
3. Placez l'incident principal dans le modèle en diamant.
4. Associez les comportements observés à des techniques MITRE ATT&CK.
5. Rédigez un rapport CTI tactique d'une page avec recommandations.

```
2026-03-01 08:02:44 user=k.mensah src=41.0.0.21 result=SUCCESS
2026-03-02 23:47:10 user=k.mensah src=203.0.113.9 result=SUCCESS
2026-03-02 23:47:58 user=k.mensah action=mass_download files=412
```

ÉTUDE DE CAS Étude de cas : campagne contre le secteur bancaire

Scénario pédagogique (fictif). En trois semaines, quatre banques d'une même zone monétaire signalent des courriels imitant leur autorité de régulation et contenant une pièce jointe piégée. Le CSIRT régional coordonne l'analyse.

1. Quelles informations partager entre banques, et sous quel format (niveau TLP) ?
2. Quels indicateurs tactiques et quels TTP retenir ?
3. Quel message stratégique adresser aux directions générales ?
4. Quelles mesures de sensibilisation des clients ?

LEÇON Glossaire de la formation

Les notions essentielles de la formation, à maîtriser pour l'examen final.

CTI

Cyber Threat Intelligence : renseignement sur les menaces cyber.

DMARC

Politique d'authentification des e-mails d'un domaine.

IoC

Indicateur de compromission (adresse, domaine, empreinte…).

MFA

Authentification multifacteur.

Modèle en diamant

Adversaire, capacité, infrastructure, victime.

STIX / TAXII

Format et protocole d'échange de la CTI.

Sigma

Format ouvert de règles de détection.

TTP

Tactiques, techniques et procédures d'un adversaire.

Typosquattage

Enregistrement de domaines proches d'une marque pour tromper.

LEÇON Pour aller plus loin : bibliographie et ressources

Sélection d'ouvrages, de normes et de ressources reconnues pour prolonger la formation. Les ressources en accès libre sont signalées.

- Caltagirone, Sergio, Pendergast, Andrew et Betz, Christopher, **The Diamond Model of Intrusion Analysis**, 2013.

  Modèle d'analyse des intrusions.

- Bianco, David J., « The Pyramid of Pain », 2013.

Hiérarchie des indicateurs selon le coût pour l'adversaire.

- OASIS, **STIX Version 2.1**, 2021.

  Standard d'échange de la CTI.

- FIRST, **Traffic Light Protocol 2.0**, 2022.

  Règles de partage.

- Union africaine, **Convention sur la cybersécurité et la protection des données à caractère personnel** (Convention de Malabo), 2014, en vigueur depuis 2023.

  Cadre continental de la protection des données.

Ces références sont indiquées à titre pédagogique ; AFRICA'SPY n'a aucun lien d'affiliation avec leurs auteurs ou éditeurs.